

GDPR Data Processing Agreement

Data Processing Agreement - Small Agency Template

Version 1.0 - August 2026

Part of ComplianceDocs by Mahope / Hermes Passiv

About This Document

A Data Processing Agreement (DPA) is required under Article 28 of the GDPR whenever an agency processes personal data on behalf of a client. This template is designed specifically for small web agencies - it is shorter, simpler, and more practical than enterprise-grade DPAs.

Who this is for: Web agencies, freelancers, and WordPress shops that handle client personal data (contact forms, membership sites, e-commerce, newsletter signups).

What you get:

- Ready-to-use DPA template (fill in the blanks)
- Annexes for data categories, technical measures, and subcontractors
- Signature blocks for both parties

Instructions

1. Replace all `[BRACKETED PLACEHOLDER]` with your information
2. Send two copies to your client - one for them, one signed and returned to you
3. Store the signed copy with your compliance documentation
4. Review annually or when your data processing changes

Data Processing Agreement

Between:

[Agency Name] , registered at [Agency Address], [VAT Number] (the "Processor")

And:

[Client Name] , registered at [Client Address], [VAT Number] (the "Controller")

Date: [Date]

1. Definitions

Terms used in this agreement have the meanings given in Article 4 of the GDPR.

- Personal Data: Any information relating to an identified or identifiable natural person
- Processing: Any operation performed on personal data (collection, storage, modification, retrieval, deletion, etc.)
- Data Subject: The identifiable natural person whose data is processed
- Subprocessor: A third party engaged by the Processor to assist in processing

2. Duration and Purpose

The Processor shall process Personal Data on behalf of the Controller for the duration of the underlying service agreement. The purpose of processing is to deliver the services described in the service agreement between the parties, including:

- [Website development and maintenance]
- [Hosting and server management]
- [Email and newsletter delivery]
- [E-commerce order processing]
- [Analytics and performance monitoring]

3. Categories of Data Subjects and Personal Data

Data Subjects:

- Website visitors and users
- Customers and clients of the Controller
- Newsletter subscribers
- Contact form submitters

Categories of Personal Data:

- Name and contact information (email, phone, address)
- IP addresses and browsing behaviour
- Account credentials
- Order/purchase history
- Any data submitted through contact forms or user accounts

4. Processor Obligations

The Processor shall:

1. Process Personal Data only on documented instructions from the Controller
2. Ensure that persons authorised to process the data are bound by confidentiality
3. Implement appropriate technical and organisational measures (see Annex A)
4. Not engage a Subprocessor without prior written authorisation (see Annex B)
5. Assist the Controller in fulfilling data subject rights requests
6. Notify the Controller within 48 hours of discovering a personal data breach
7. Delete or return all Personal Data at the end of the service agreement
8. Make available all information necessary to demonstrate compliance with this DPA

5. Subprocessors

The Controller authorises the Processor to engage the Subprocessors listed in Annex B. The Processor shall:

- Notify the Controller at least 30 days before adding or replacing any Subprocessor
- Enter into a written agreement with each Subprocessor imposing equivalent data protection obligations
- Remain fully liable for Subprocessor compliance

6. Data Breach Notification

In the event of a personal data breach, the Processor shall:

1. Notify the Controller within 48 hours of detection
2. Provide: nature of the breach, categories and approximate number of data subjects affected, contact details for the Processor's Data Protection contact
3. Document all breaches, including facts, effects, and remedial actions

7. Data Subject Rights

The Processor shall assist the Controller in responding to data subject requests under Articles 15-22 of the GDPR, including:

- Right of access (Article 15)
- Right to rectification (Article 16)
- Right to erasure (Article 17)
- Right to data portability (Article 20)

The Processor shall respond to Controller requests for assistance within 5 business days.

8. Deletion and Return

Upon termination of the service agreement, the Processor shall:

1. At the Controller's choice: delete all Personal Data or return it in a structured format
2. Delete existing copies unless EU law requires storage
3. Provide written confirmation of deletion within 30 days

9. Liability

The Processor shall notify the Controller of any data protection-related claims. Liability for breach of this DPA shall be governed by the underlying service agreement.

10. Governing Law

This DPA shall be governed by [EU/GDPR implementing law of your member state, e.g. Danish Data Protection Act].

Annex A: Technical and Organisational Measures

The Processor implements the following measures:

Access Control:

- Least-privilege access for all employees and contractors
- Role-based access controls on all systems
- Quarterly access reviews

Authentication:

- Multi-factor authentication on all administrative accounts
- Minimum 16-character passwords stored in a password manager
- Automatic account lockout after 5 failed attempts

Encryption:

- Data in transit: TLS 1.2+ on all web traffic, encrypted backup uploads
- Data at rest: AES-256 encryption on backup storage
- Server-level disk encryption where available

Backups:

- Daily automated backups with 30-day retention
- Quarterly restoration tests (documented)
- Encrypted offsite storage

Monitoring:

- Security plugin monitoring on all client sites
- Weekly vulnerability scanning
- Incident response plan (notification within 48 hours)

Personnel:

- Confidentiality agreements for all employees and contractors
- Annual security awareness briefing (30 minutes)
- Background checks where legally permitted

Annex B: Authorised Subprocessors

* Provider

* Service

* Data Location

* EU/EEA

* [Hosting provider]

* Server hosting

* [Location]

- * [Yes/No]
- * [Email provider]
- * Email delivery
- * [Location]
- * [Yes/No]
- * [CDN provider]
- * Content delivery
- * [Location]
- * [Yes/No]
- * [Backup provider]
- * Backup storage
- * [Location]
- * [Yes/No]

Notification of Changes: The Processor shall notify the Controller at least 30 days before engaging a new Subprocessor. If the Controller objects, the parties shall discuss in good faith.

Annex C: Signature Block

Signed for the Controller:

Name: _____

Title: _____

Date: _____

Signature: _____

Signed for the Processor:

Name: _____

Title: _____

Date: _____

Signature: _____

Delivery

This is a template document. Fill in your details, add your logo, and convert to PDF for client delivery.

Format: Markdown (convert to PDF via Pandoc, Google Docs, or your preferred tool)

Price when published: \$14.99 (Gumroad)

Disclaimer: This document provides a template based on standard GDPR/DPA requirements. It does not constitute legal advice. Have your legal counsel review before use, especially if processing special categories of data or handling large volumes of personal data.

EAA Accessibility Statement

EAA Accessibility Statement Template

Version 1.0 - August 2026

Part of ComplianceDocs by Mahope / Hermes Passiv

About This Document

The European Accessibility Act (EAA) requires that public-facing websites in the EU carry an accessibility statement explaining their status against the Web Content Accessibility Guidelines (WCAG). This template is designed specifically for small web agencies to give their clients a compliant statement.

Who this is for: Web agencies, freelancers, and WordPress shops adding EAA compliance statements to client sites.

What you get:

- Complete accessibility statement template
- Instructions for assessing your site's compliance level
- Guidance on what to say when your site is not fully compliant (most sites aren't)

Instructions

1. Run your site through a free accessibility checker (see tools below)
2. Fill in the `[BRACKETED]` fields based on your assessment
3. Publish on your website - typically in the footer and an `/accessibility` page
4. Update annually or whenever your site design changes significantly

Recommended Free Tools

- * Tool
- * URL
- * What It Checks
- * WAVE Web Accessibility Tool
- * <https://wave.webaim.org>
- * Full page audit with visual overlays
- * axe Browser Extension
- * Deque's axe DevTools
- * Automated WCAG 2.1 AA checks
- * Lighthouse (Chrome DevTools)
- * Built into Chrome
- * Accessibility score + recommendations

- * Colour Contrast Analyzer
- * <https://webaim.org/resources/contrastchecker>
- * Specific colour pair checks
- * HTML Validator
- * <https://validator.w3.org>
- * Structural markup compliance

Accessibility Statement

Last updated: [Date]

Website: [Client Website URL]

1. Commitment

[Client Name] is committed to ensuring digital accessibility for all users, regardless of ability. We are continuously improving the user experience for everyone and applying the relevant accessibility standards.

2. Compliance Status

This website is [fully / partially / not yet] compliant with the European Accessibility Act (EAA) and Web Content Accessibility Guidelines (WCAG) 2.1 Level AA.

Choose one:

> Fully compliant: This website meets all WCAG 2.1 AA requirements. We continuously monitor and maintain compliance.

> Partially compliant: This website partially meets WCAG 2.1 AA standards. Some content may not fully conform. We are actively working to resolve identified issues.

> Not yet compliant: This website has not yet been fully assessed for EAA compliance. We are in the process of auditing and updating our content.

3. What We Have Done

We have implemented the following measures to improve accessibility:

- Added alternative text to all images (informative and functional images)
- Ensured sufficient colour contrast between text and background
- Structured content with proper heading hierarchy (h1-h6)
- Made all functionality available from a keyboard
- Added skip-to-content navigation links
- Ensured form inputs have associated labels

- Provided descriptive link text (no "click here" or "read more")

4. Known Limitations

Despite our best efforts, some content may not yet be fully accessible. We are working to address these known issues:

- * Issue
- * Status
- * Target Date
- * [e.g., Older PDF documents]
- * [In progress / Planned]
- * [Q4 2026]
- * [e.g., Third-party embedded content]
- * [Requires vendor action]
- * [Q2 2027]
- * [e.g., Video content without captions]
- * [In progress]
- * [Q4 2026]

5. What to Do If You Encounter a Barrier

If you find any content or feature on this website that is not accessible to you, please contact us:

- Email: [accessibility@yourdomain.com]
- Phone: [Optional]
- Response time: We will acknowledge your report within 5 business days and provide a timeline for resolution.

We take your feedback seriously and will make reasonable accommodations to ensure equal access to our content and services.

6. Assessment Method

This statement was prepared using:

- [Automated testing tools used]
- [Manual testing date]
- [Date of most recent review]

7. Review Cycle

This accessibility statement is reviewed and updated:

- When the website design changes significantly
- When new content types are added
- At minimum annually

Next review date: [Date, 12 months from now]

Appendix: Quick EAA Reference for Web Agencies

EAA Key Requirements for Websites

- * Requirement
- * WCAG Reference
- * What to Check
- * Perceivable (users must be able to perceive content)
 - * 1.1.1 Non-text Content
 - * Alt text on images
 - * 1.4.3 Contrast Minimum
 - * 4.5:1 contrast ratio for normal text
- * Operable (users must be able to operate the interface)
 - * 2.1.1 Keyboard
 - * All functions available from keyboard
 - * 2.4.1 Bypass Blocks
 - * Skip-to-content link
- * Understandable (users must be able to understand content)
 - * 3.2.2 On Input
 - * Forms don't auto-submit unexpected
 - * 3.3.2 Labels
 - * All form fields have labels
- * Robust (content works across assistive technologies)
 - * 4.1.1 Parsing
 - * Valid HTML, proper ARIA usage
 - * 4.1.2 Name, Role, Value
 - * Interactive elements have accessible names

EAA Enforcement

- Deadline: June 28, 2025 (passed - now enforced)
- Sanctions: Member state-specific. EU guidance recommends proportionate penalties.
- First enforcement actions seen: 2026 (member states beginning active enforcement).
- Risk for agencies: Enterprise clients in EAA scope are now requiring their vendors to demonstrate accessibility compliance.

Monthly Maintenance Checklist

- [] Run automated scan (5 min with WAVE or axe)
- [] Check new content for alt text and heading structure
- [] Test any new third-party embeds (videos, forms, interactive tools)
- [] Log issues for next development sprint

Delivery

Format: Markdown (fill in blanks, convert to HTML for website)

Price when published: \$9.99 (Gumroad)

Disclaimer: This document provides a template based on publicly available EAA/WCAG requirements. It does not constitute legal advice. Accessibility requirements may vary by member state implementation of the EAA.

NIS2 Contract Clauses

NIS2 Contract Clause Pack - Small Web Agencies

Version 1.0 - August 2026

Part of ComplianceDocs by Mahope / Hermes Passiv

About This Document

A pack of 8 ready-to-use contract clauses covering NIS2 cybersecurity requirements. Each clause includes the legal text, a plain-English explanation, and guidance on where to place it in your contract.

Who this is for: Web agencies, managed service providers, freelancers, and WordPress shops serving EU enterprise clients.

What you get:

- 8 standalone clauses ready to copy into your contracts
- Explanations so you know what each clause actually does
- Guidance on which clauses to prioritise by client type

Quick Reference - Which Clauses to Use

* Client Type

* Must Have

* Nice to Have

* Enterprise (250+ emp)

* 1, 2, 4, 5, 7

* 3, 6, 8

* SME (50-249 emp)

* 1, 2, 4, 5

* 3, 7

* Small business (<50 emp)

* 1, 2

* 4, 5

* Public sector

* 1, 2, 3, 4, 5, 6, 7

* 8

Clause 1: Security Obligations (Core)

Purpose: Sets the baseline security standard you commit to maintaining.

Placement: Main body of service agreement, under "Obligations of Provider"

1.1 The Provider shall maintain appropriate technical and organisational security measures to protect the Client's data and systems throughout the term of this agreement.

1.2 Without limiting the generality of clause 1.1, the Provider shall implement and maintain:

- (a) Access controls based on the principle of least privilege;
- (b) Encryption of data in transit (TLS 1.2 or higher) and at rest (AES-256);
- (c) Multi-factor authentication on all administrative systems;
- (d) Regular security patching of all systems within 7 days of release;
- (e) Daily automated backups with monthly restoration testing;
- (f) An incident response plan capable of notification within 24 hours.

1.3 The Provider shall review and update these measures at least annually and shall notify the Client of any material changes.

Clause 2: Incident Notification (NIS2 Timeline)

Purpose: Aligns your incident reporting with NIS2's strict timeline.

Placement: Security section, immediately after Clause 1

2.1 The Provider shall notify the Client's designated security contact within 24 hours of becoming aware of any security incident affecting the Client's data or systems.

2.2 The notification shall include at minimum:

- (a) A description of the incident and its status (ongoing, contained, or resolved);
- (b) The systems and data affected;
- (c) Immediate actions taken;
- (d) A timeline for the next update.

2.3 Within 72 hours of detection, the Provider shall deliver a detailed incident report including:

- (a) Root cause analysis;
- (b) Full scope of impact;
- (c) Remediation steps taken;
- (d) Preventive measures to avoid recurrence.

2.4 "Security incident" means any event having an actual adverse effect on the security of the Client's network or information systems, including but not limited to: unauthorised access, data breach, ransomware, denial of service, or compromise of

administrative credentials.

...

Clause 3: Subcontractor and Supply Chain

Purpose: Gives clients visibility into your subcontractors, as NIS2 requires supply chain assessment.

Placement: After incident notification clause

...

3.1 The Provider shall maintain a list of all subcontractors and third-party service providers with access to Client data or systems and shall provide it within 10 business days of the Client's written request.

3.2 The Provider shall ensure that each subcontractor maintains security measures equivalent to those described in this agreement, documented in a written agreement between the Provider and the subcontractor.

3.3 The Provider shall notify the Client at least 30 days before engaging any new subcontractor that will have access to Client data or systems. If the Client objects on reasonable security grounds, the Provider may either (a) propose an alternative subcontractor, or (b) maintain security without the objected subcontractor.

3.4 The Provider remains fully liable for all acts and omissions of its subcontractors as if they were the Provider's own.

...

Clause 4: Data Processing and Location

Purpose: Addresses GDPR data processing requirements alongside NIS2.

Placement: Data processing section

...

4.1 The Provider shall process Client data only in accordance with the Client's documented instructions, and not for any other purpose.

4.2 All Client data shall be stored and processed within the European Economic Area (EEA) unless:

- (a) The Client gives prior written consent to processing outside the EEA; and
- (b) Adequate safeguards under Article 46 GDPR are in place.

4.3 The Provider shall maintain a Data Processing Agreement (DPA) in accordance with Article 28 GDPR and shall provide it upon request or within 15 days of the Client's

demand.

4.4 The Provider shall not transfer Client data to a third country without the Client's express written consent and appropriate transfer mechanisms (Standard Contractual Clauses or adequacy decision).

Clause 5: Audit and Verification

Purpose: Lets clients verify your compliance without disrupting your operations.

Placement: Compliance or audit section

5.1 Upon the Client's reasonable request (not more than once per 12-month period), the Provider shall complete a security questionnaire provided by the Client and return it within 15 business days.

5.2 The Provider shall provide documentary evidence of the security measures described in this agreement, which may include:

- (a) A copy of the Provider's Information Security Policy (redacted for confidentiality);
- (b) Evidence of annual security testing or penetration testing;
- (c) Certification under ISO 27001, SOC 2 Type II, or equivalent standard (if held);
- (d) Records of backup restoration tests.

5.3 The Client may conduct a security assessment of the Provider's relevant systems, provided that: (a) the assessment is conducted by an independent third party; (b) reasonable notice (minimum 30 days) is given; (c) the assessment does not unreasonably disrupt the Provider's operations; and (d) findings are shared with the Provider.

Clause 6: Liability and Indemnity for Security Breaches

Purpose: Clarifies liability allocation for security incidents.

Placement: Liability section

6.1 Each party shall notify the other party promptly upon becoming aware of any circumstance that could give rise to a claim under this clause.

6.2 The Provider shall indemnify the Client against direct damages resulting from a security incident caused by the Provider's failure to maintain the security measures

required under this agreement.

6.3 The Client shall indemnify the Provider against direct damages resulting from a security incident caused by the Client's systems, data, or failure to follow the Provider's reasonable security instructions.

6.4 Neither party shall be liable for indirect, consequential, or incidental damages arising from a security incident, except where such limitation is prohibited by applicable law.

6.5 This clause survives termination of the agreement for a period of 12 months.

Clause 7: Compliance with Laws (NIS2, GDPR, EAA)

Purpose: Broad compliance representation covering multiple EU regulations.

Placement: Representations and warranties section

7.1 The Provider represents and warrants that it shall comply with all applicable laws governing the services provided under this agreement, including but not limited to:

- (a) The EU Network and Information Security Directive (NIS2);
- (b) The General Data Protection Regulation (GDPR);
- (c) The European Accessibility Act (EAA), where applicable to services provided.

7.2 The Client represents and warrants that it shall provide accurate and complete information necessary for the Provider to fulfil its obligations under this clause.

7.3 Both parties shall cooperate in good faith to address any changes in applicable laws during the term of this agreement.

Clause 8: Termination for Security Non-Compliance

Purpose: Gives both parties an exit if security standards are not maintained.

Placement: Termination section

8.1 If either party fails to maintain the security measures required under this agreement, and such failure materially affects the security of the other party's data or systems, the non-breaching party may give written notice specifying the non-compliance.

8.2 The breaching party shall remedy the non-compliance within 30 days of the notice.

8.3 If the non-compliance is not remedied within the cure period, the non-breaching party may terminate the agreement immediately upon written notice.

8.4 Upon termination under this clause, the Provider shall return or destroy all Client data (at the Client's direction) within 15 days.

Implementation Checklist

- ☐ Copy relevant clauses into your standard contract template
- ☐ Update your Information Security Policy to match what you've committed to
- ☐ Ensure your actual security practices match the clauses (don't promise what you don't do)
- ☐ Train your team on the incident notification timeline (24h / 72h)
- ☐ Review annually - NIS2 enforcement guidance may evolve

Delivery

Format: Markdown (copy clauses directly into your contracts)

Price when published: \$12.99 (Gumroad)

Disclaimer: This document provides contract clause templates based on publicly available NIS2 requirements. It does not constitute legal advice. Have your legal counsel review all clauses before including them in binding agreements.

Vendor Security Assessment Checklist

Vendor Security Assessment Checklist - Small Web Agencies

Version 1.0 - August 2026

Part of ComplianceDocs by Mahope / Hermes Passiv

About This Document

Under NIS2, enterprise clients must assess their supply chain security - and you, as their web agency, are part of that supply chain. This checklist helps you:

1. Answer the security questionnaires clients send you (as a vendor)
2. Assess your own subcontractors and service providers
3. Build your Vendor Security Profile - a proactive document you share in pitches

Who this is for: Web agency owners, freelancers, and managed service providers who need to demonstrate security compliance to enterprise clients.

What you get:

- The 10 most common client security questions (with model answers)
- A vendor assessment scorecard for your own suppliers
- A template for your Vendor Security Profile
- Integration tracking spreadsheet format

Part 1: The 10 Most Common Client Security Questions

Based on actual NIS2 procurement questionnaires from EU enterprises (2025-2026). These appear in nearly every vendor assessment.

How to use: Prepare written answers to all 10. Store them in a document called "Vendor Security Profile" (see Part 3). Update annually.

Q1: Do you have a documented Information Security Policy?

What they're looking for: Evidence that you have formalised your security approach.

Model answer:

Yes. Our Information Security Policy is a one-page document covering:

- Access control (least privilege, quarterly review)
- Authentication (MFA, 16+ character passwords)

- Data protection (encryption at rest and in transit, EU-only storage)
- Incident response (24h notification)
- Software updates (patches within 7 days)
- Third-party security requirements

Last reviewed: [Date]. Review cycle: Annual.

Do if you don't have this: See Appendix A of "NIS2 Compliance for Small Web Agencies" - a sample policy template ready to copy.

Q2: What backup procedures do you follow?

What they're looking for: Proof you can recover from data loss.

Model answer:

We follow the 3-2-1 backup rule:

- 3 copies of client data (production + 2 backups)
- 2 different media types (cloud + on-site)
- 1 offsite copy

Backup schedule:

- Client sites: daily automated backups
- Databases: hourly incremental
- Retention: 30-day rolling with monthly snapshots

We test restoration quarterly and document each test. Last test: [Date].

Q3: Are you certified under ISO 27001, SOC 2, or equivalent?

What they're looking for: Third-party validation of your security practices.

Model answer (choose one):

a) Yes, we are ISO 27001:2022 certified. Certificate available upon request.

b) We follow ISO 27001 principles but are not formally certified (self-assessed alignment).

For a small agency, self-assessment aligned to ISO 27001 controls is a practical and accepted approach for non-critical vendors.

c) We are SOC 2 Type II audited. Report available under NDA.

Honesty matters: If you're not certified, say so. A self-assessment with documented practices is accepted for small vendors. Lying about certification will end the relationship when discovered.

Q4: Where is client data stored and processed?

What they're looking for: GDPR compliance - data must stay in the EEA unless otherwise agreed.

Model answer:

...

All client data is stored and processed within the European Economic Area (EEA).

- Primary hosting: [Provider], [Location - e.g., Frankfurt, Germany]
- Backup storage: [Provider], [Location]
- Data transit: Encrypted via TLS 1.2+ at all times

We do not transfer client data outside the EEA unless expressly authorised in writing.

...

Q5: What access controls do you have in place?

What they're looking for: Protection against insider threats and credential misuse.

Model answer:

...

- Least-privilege access: every employee gets only the access needed for their role
- Role-based access control across all systems (hosting, DNS, email, WordPress admin)
- MFA required on all administrative accounts
- Quarterly access review and removal of unused accounts
- Employee accounts terminated within 24 hours of departure
- All access logged and logs retained for 90 days

...

Q6: Do you conduct regular security testing?

What they're looking for: Proactive vulnerability detection.

Model answer:

...

Yes. Our testing schedule:

- Automated vulnerability scanning: quarterly (HackerTarget / WPScan / equivalent)
- Manual access log review: monthly
- Backup restoration test: quarterly

- Penetration testing: annually (or when significant infrastructure changes occur)

All test results are documented and reviewed with remediation within 15 days.

...

Q7: How do you handle incidents?

What they're looking for: A defined incident response process, not ad hoc.

Model answer:

...

We follow a 6-step Incident Response Plan:

1. Detect (automated monitoring, user reports, client notification)
2. Triage (severity assessment within 15 minutes)
3. Contain (isolate affected systems, preserve evidence)
4. Eradicate (remove root cause, apply patches)
5. Recover (restore from clean backup, verify integrity)
6. Review (root cause analysis within 7 days, update procedures)

Client notification timeline: 24 hours for early warning, 72 hours for full report.

Documented plan available upon request.

...

Q8: Do you conduct background checks on employees?

What they're looking for: Personnel security.

Model answer:

...

Where legally permitted, we conduct:

- Reference checks for all new hires
- Confidentiality agreements signed by all employees and contractors
- Security awareness briefing within 30 days of start date

Full background checks (criminal records, credit checks) are conducted for roles involving access to sensitive financial or health data, where permitted under local law.

...

Q9: Do you use subcontractors or third parties that handle client data?

What they're looking for: Supply chain awareness - they're assessing your supply chain, so they need to know yours.

Model answer:

...

We use the following third parties that may process client data:

- * Provider
- * Service
- * Security Certification
- * DPA Available
- * [Host]
- * Server hosting
- * SOC 2 Type II
- * Yes
- * [DNS]
- * DNS management
- * ISO 27001
- * Yes
- * [Email]
- * Email delivery
- * SOC 2 Type II
- * Yes
- * [CDN]
- * Content delivery
- * ISO 27001
- * Yes

Full list available upon request. All subcontractors are contractually required to maintain security measures equivalent to our own.

...

Q10: What is your password policy?

What they're looking for: Credential hygiene.

Model answer:

...

- Minimum password length: 16 characters
- Complexity: mixed case, numbers, special characters required
- MFA: enabled on all administrative accounts
- Password manager: Bitwarden (enterprise) - no passwords stored in email or spreadsheets
- No shared accounts: every user has unique credentials
- Account lockout: after 5 failed attempts, 15-minute lockout
- Review: all credentials reviewed quarterly

...

Part 2: Vendor Assessment Scorecard (For Your Own Suppliers)

Use this table to assess each third-party service you rely on. Score each criterion 0-2:

- 0 = No evidence available / not compliant
- 1 = Self-attested / partially documented
- 2 = Certified / contractually guaranteed

* Criterion

* Weight

* Provider A

* Provider B

* Provider C

* Security certification (SOC 2 / ISO 27001)

* 3

* Published security page

* 1

* DPA available

* 2

* EU data residency

* 2

* Incident notification SLA

* 2

* Encryption (at rest + in transit)

* 2

* Access controls (MFA, least privilege)

* 1

* Uptime SLA

* 1

* Total Weighted Score

* /14

* /14

* /14

Score interpretation:

- 12-14: Strong vendor - well-documented, certified
- 8-11: Acceptable - documented but not certified
- 0-7: Replace or require improvement plan

Part 3: Vendor Security Profile Template

Compile answers from Part 1 into a single document. Add your letterhead, convert to PDF, and keep it ready.

Structure:

...

1. ABOUT [AGENCY NAME]

- Company overview, years in business
- Services provided
- Client industries served

2. SECURITY AT A GLANCE

- Certification status (ISO 27001 / SOC 2 / self-assessed)
- Security contact: [name/email]
- Last security review: [date]

3. INFORMATION SECURITY POLICY SUMMARY

- 1-page summary of your policy

4. ANSWERS TO SECURITY QUESTIONNAIRE

- Q1-Q10 as prepared above

5. SUBCONTRACTOR LIST

- Table of third parties

6. INCIDENT HISTORY

- Number of reportable incidents in last 12 months
- Lessons learned (if any)

7. CONTACT

- Security: security@yourdomain.com
- Emergency: [phone number, if applicable]

...

Delivery

Format: Markdown (compile into PDF for client delivery)

Price when published: \$14.99 (Gumroad)

Disclaimer: This checklist is based on publicly available NIS2 procurement practices and industry standards. Requirements vary by client. Customise answers to reflect your actual practices - never claim measures you have not implemented.